Table of Contents

Report D2 — What Microsoft Word protects against, and what it does not (2026)
- Method
- Results
- Conclusions
- What this means for jubarte

Report D2 — What Microsoft Word protects against, and what it does not (2026)

Status: final (2026-10-31). Every fixture but E6 was opened in Word alone. Two jubarte binaries were run on all 33 fixtures: 0.16.0+6bf2efb43 (the 0.17.0 pre-release, *before*) and 0.16.0+c995f2d46 (the bomb-hardening branch, *after*).

Companion to `jubarte-redlines/docs/bomb_prevention.md`, which carries the full before/after table. This report sets Word's behaviour beside jubarte's and says what each conclusion means for jubarte.

Raw evidence, scripts and the run journal are in `logs/word-exp/` (`LOG.md`, `results_word.tsv`, `results_jubarte*.tsv`, `cmp_scale/`, `runs/ID/word.log`, `screen.log`, `net.log`). The hostile fixtures and the jubarte run outputs are not published; the five `scripts/build*.py` rebuild all 33 fixtures.

Method

- **Word:** only through `neurotic_docx_bench/scripts/word_pdf.py` (open, then export to PDF), one fixture per run, alone, `--timeout 300`.
  - The bench watchdog ran on that run's own log, and `word_screen_log.py` recorded every dialog.
  - Word's RSS was sampled every second, with a 10 GB kill guard.
  - Verdict: **CLEAN** = PDF written and no dialog. Anything else is a refusal, an alert, a hang or a failure.
  - A file that failed twice was not retried (D_tbl60, D_tbl200).
- **Network:** a listener on `127.0.0.1:18009` logs every connection (`net.log`). The doc's B7 aims at `127.0.0.1:9` and `\\127.0.0.1\share`. Ports below 1024 need root, so B7 cannot be observed directly; N1–N4 aim the same shapes at the listener.
- **Canary:** B5's external entity points at a file holding `CANARY_SECRET_7f3a`; the PDF text is checked for it.
- **jubarte:** `read` (default and `--no-page-markers`), `validate`, and `compare FILE C0`, each under a 6 GB / 300 s guard.
- **Fixtures:** B1–B10 are the doc's packages, built by `editors_trial/build/make_bombs.py` unchanged. The others are described in the table.

Results

Fixture	Shape	Word	Word peak RSS	jubarte after (c995f2d46)
C0	one paragraph (control)	CLEAN, 1 page	506 MB	ok
B1	one `w:t` of 66 MiB of spaces (68 KB zipped)	**CLEAN**, 1 page, 7 s	711 MB	refused by every command (part cap; `compare`: story budget, 0.9 s, 831 MB). Before: `compare` killed at 300 s
B2	25,000 `customXml` parts	**CLEAN**	460 MB	refused: `INPUT_LIMIT` (entries)

Fixture	Shape	Word	Word peak RSS	jubarte after (c995f2d46)
B3	500,000 attributes on one `w:p`	**refused**: "Word experienced an error trying to open the file."	615 MB	refused: `INVALID_XML` (> 1,024 attributes)
B4	5,000-deep `w:sdt` + 250-deep `w:tbl`	**refused**: same error	511 MB	refused: nesting
D_sdt200/300/600	`w:sdt` chains 200 / 300 / 600 deep	**CLEAN**, leaf text present	559–619 MB	200: `read` writes it, `validate` and `compare` refuse at 256. 300, 600: refused
D_tbl60	nested tables 60 deep (948 bytes)	**hung**, twice (AppleEvent timeout at 375 s)	509 MB	read, validated and compared in ≤ 1 MB
D_tbl200/300	nested tables 200 / 300 deep	**hung** at 376 s; D_tbl300 crashed Word on an earlier run	515 MB	refused: nesting
B5	billion-laughs entities (10^6) + external entities (`/etc/hosts`, canary)	**refused**: same error; canary absent	470 MB	refused: DTD declarations are unsupported. Before: exit 0, entities kept literal
X1	a bare `<!DOCTYPE w:document>`	**refused**: same error	1.5 GB	refused (before: exit 0)
X2	internal entity used in text	**refused**: same error	470 MB	refused (before: exit 0, `ENT[&a;]` kept literal)
X3	internal entity whose value holds a `>`	**refused**: same error	467 MB	refused (before: exit 0, smuggled paragraph absent)
X4	the same DOCTYPE in a `customXml` item	**alert**: unreadable content, then refused	464 MB	refused, naming `customXml/item1.xml` (before: exit 0)
X4c	X4 without the DOCTYPE (control)	**CLEAN**	514 MB	ok
X5	the same DOCTYPE in `styles.xml`	**alert**: unreadable content, then refused	470 MB	refused, naming `word/styles.xml` (before: exit 0)
B6	zip-slip entry `../escaped/...` + traversal relationships	**alert**: unreadable content; no slipped file anywhere	440 MB	`read` writes the body and warns; `validate` and `compare` refuse the name
B7	external template on `127.0.0.1:9` + UNC subDocument	**CLEAN**, 1 page (not observable without root)	501 MB	body only; no connection
B8	`javascript:` hyperlink + altChunk HTML with script	**refused**: same error	457 MB	body only; `validate` exits 2
B9	`gridSpan` 1,000,000 + 2,000 field begins + 60,000 sources	**CLEAN**, 77 pages	545 MB	span capped at 64; 144 MB; `validate` exits 2
B10	non-UTF-8 styles, truncated comments, fake PNG	**alert**: unreadable content	473 MB	`read` writes the body and warns; `validate` and `compare` refuse
N1	remote template → listener	**CLEAN, and fetched it**: OPTIONS, HEAD, GET, no prompt	515 MB	body only; no connection
N2	linked picture (`a:blip r:link`) → listener	**CLEAN, and fetched it 8 times**, no prompt	488 MB	body only; no connection
N3	`INCLUDEPICTURE` → listener	**CLEAN**; no fetch	502 MB	field instruction and cache kept in the view
N4	`w:subDoc` → listener	**CLEAN; HEAD probe** ("Microsoft Office Existence Discovery")	489 MB	body only; `compare` is `UNSUPPORTED_CONTENT` (before: panic, exit 101)
E1	1 MiB element flood	**CLEAN**, 1,187 pages, 15 s	765 MB	exit 0, 106 MB; `compare` 601 MB

Fixture	Shape	Word	Word peak RSS	jubarte after (c995f2d46)
E2	8 MiB element flood	**CLEAN**, 9,490 pages, 89 s	2.36 GB	exit 0, 777 MB; `compare` 78 s, 5.0 GB
E5	1,999,817 elements, just inside jubarte's budget	**CLEAN**, 25,639 pages, 237 s	3.9 GB	exit 0, 2.2 GB (2.9 GB without page markers); `compare` refused (story budget) in 2 s
E6	2,001,017 elements, just past it	not run		refused (elements) in 2 MB
E3	60 MiB element flood (215 KB zipped)	**failed** after 1,641 s	6.2 GB	refused (elements), 136 MB (before: exit 0 at 5.5 GB)
E4	70 MiB element flood	**failed** after 1,610 s	7.2 GB	refused (part cap), ≤ 1 MB (before: 4.4 GB first)

On E4 the canary file's access time changed during Word's 27-minute run. E4 references no canary, and Word wrote no PDF; the access is unexplained and is not counted as a leak.

Conclusions

1. **Word refuses every DTD, in every part.** A bare `<!DOCTYPE>` (X1), the entity bomb (B5), and a DOCTYPE in `styles.xml` (X5) or in a `customXml` item (X4) are all refused; X4 without it (X4c) is CLEAN. jubarte now refuses the same, so it loses no Word-valid input.
2. **Word refuses attribute floods and extreme depth** (B3, B4), as jubarte does. But Word opens a 600-deep `w:sdt` chain, which jubarte refuses: that depth cap is jubarte's own choice, not Word's.
3. **Word is more permissive on size and entries** (B1: a 66 MiB run; B2: 25,000 parts), and jubarte refuses both. These caps are deliberate and not Word-faithful; overrides lift them.
4. **Word does not protect itself from element floods or nested tables.** A 60 or 70 MiB flood made it fail after about 27 minutes at 6–7 GB. A 948-byte nest of 60 tables hung it twice. jubarte refuses a flood past its element budget in a few MB and reads the nested tables in a second.
5. **Word is a network beacon.** It fetched a remote template (N1) and a linked picture (N2, eight times), and probed a subdocument (N4), with no prompt. jubarte has no network code on any document path, and CI checks that this stays so.
6. **jubarte's own weak spot was `compare`, not `read`.** The comparer makes an atom of 2–4 KB per character, so B1, which Word opens in 7 s, passed 6 GB in four seconds, and a subdocument (N4) crashed it. Both are now refused before any atom, but the bound is a bound: a side just under it (E2) still costs 78 s and 5 GB. A smaller atom is the real fix.

What this means for jubarte

- **Word refuses it, jubarte refuses it:** DTDs anywhere, attribute floods, B4, active content (B8 in Word). No Word-validity cost.
- **Word opens it, jubarte refuses it:** a 66 MiB part, 25,000 entries, content controls 300 to 600 deep, and, for `compare` only, a side past the story budget (B1, E5) or holding a subdocument, altChunk or custom XML. All are documented, and all but the nesting cap and the unsupported content are overrides.
- **Word is hurt by it, jubarte is not:** element floods, deep tables, and every network reference.